

VTU MCA 2022/2024 SCHEME • QUESTION BANK WITH COMPLETE ANSWER KEYS



QB 10: Cybersecurity & Ethical Hacking — Question Bank with Answer Keys

Course: Cybersecurity & Ethical Hacking (Elective / Core Specialization)

Target: VTU MCA Semester 3 + Student DevSecOps Career Path

Scheme: VTU 2022 / 2024 Scheme

Contents: CIA Triad, RSA Cryptography Numericals, Diffie-Hellman Key Exchange, OWASP Top 10 Exploit Mitigations, Firewalls & IDS/IPS, 15 MCQs with Explanations



Syllabus Outline (VTU 5 Modules)

- **Module 1:** Principles of Information Security, CIA Triad, Threat Modeling (STRIDE), Attack Vectors (Malware, Ransomware, Phishing, DDoS, MITM).
- **Module 2:** Cryptography: Symmetric (AES) vs Asymmetric (RSA), Diffie-Hellman Key Exchange, Cryptographic Hashing (SHA-256), Digital Signatures, PKI & X.509 Certificates.
- **Module 3:** Web Security & OWASP Top 10: SQL Injection (SQLi), Cross-Site Scripting (XSS), Cross-Site Request Forgery (CSRF), Broken Access Control, Parameterized Queries.
- **Module 4:** Network Defense: Firewalls (Packet Filtering, Stateful Inspection, WAF), IDS vs IPS (Signature vs Anomaly), VPNs (IPsec), DMZ Architecture, Zero Trust Architecture.
- **Module 5:** Ethical Hacking & Incident Response: 5 Phases of Penetration Testing, Security Tools (Nmap, Wireshark, Burp Suite, Metasploit), SOC Basics, NIST Incident Response Lifecycle.



SECTION 1: High-Yield MCQs with Answer Key

Q1. Which pillar of the CIA Triad is violated if an attacker modifies the balance in a bank database?

- A) Confidentiality
- B) Integrity
- C) Availability
- D) Non-repudiation

Answer: B

Explanation: Integrity guarantees that data has not been altered or tampered with in transit or storage by unauthorized parties.

Q2. In RSA asymmetric encryption, if an email is encrypted using the recipient's Public Key, who can decrypt it?

- A) Anyone with the sender's public key
- B) Only the recipient using their private key
- C) The sender using their private key
- D) Any certificate authority

Answer: B

Explanation: Data encrypted with a public key can only be decrypted by the matching private key, ensuring confidentiality.

Q3. Which technique is the most effective defense against SQL Injection attacks?

- A) Running the database on non-standard ports
- B) Using Prepared Statements (Parameterized Queries) and ORM frameworks
- C) Storing passwords in plaintext
- D) Client-side JavaScript validation only

Answer: B

Explanation: Prepared statements separate SQL query code from user data input, ensuring the database engine treats input strictly as literal values rather than executable code.

Q4. What type of Cross-Site Scripting (XSS) occurs when malicious JavaScript is permanently stored in a database and served to visiting users?

- A) Reflected XSS
- B) Stored (Persistent) XSS
- C) DOM-based XSS
- D) Blind XSS

Answer: B

Explanation: Stored XSS occurs when untrusted script is saved to a server database (e.g., in a comment section) and executes in the browsers of all users viewing that page.

Q5. What is the fundamental security premise of "Zero Trust Architecture"?

- A) Trust everyone inside the corporate local network
- B) "Never trust, always verify" — every request is authenticated and authorized regardless of network location
- C) Disable all firewalls
- D) Use only symmetric keys

Answer: B

Explanation: Zero Trust eliminates the concept of an implicit trusted perimeter, continuously validating every user, device, and API request.

Q6. Which cryptographic hash property ensures that it is computationally infeasible to find ANY two distinct inputs x and y such that $\text{Hash}(x) = \text{Hash}(y)$?

- A) Pre-image resistance
- B) Second pre-image resistance
- C) Collision resistance
- D) Entropy

Answer: C

Explanation: Collision resistance means it is practically impossible to find any two different messages that produce identical hash outputs.

Q7. What port scanning tool is widely known as the "network mapper" in penetration testing?

- A) Burp Suite
- B) Nmap
- C) John the Ripper
- D) Snort

Answer: B

Explanation: Nmap is the industry-standard network discovery and security auditing scanner used to identify live hosts and open ports.

Q8. What is the primary difference between an IDS (Intrusion Detection System) and an IPS (Intrusion Prevention System)?

- A) IDS only monitors and alerts; IPS actively blocks or terminates detected malicious traffic in-line
- B) IDS is hardware-only; IPS is software-only
- C) IDS prevents DDoS; IPS does not
- D) There is no difference

Answer: A

Explanation: An IDS sits out-of-band to inspect and alert; an IPS is positioned directly in-line to actively drop malicious packets and reset suspicious connections.

Q9. What security mechanism prevents Cross-Site Request Forgery (CSRF) by ensuring that requests are only accepted if initiated from the same origin?

- A) Anti-CSRF Synchronizer Tokens and SameSite Cookie Attribute
- B) MD5 hashing
- C) Base64 encoding
- D) VPN tunneling

Answer: A

Explanation: Anti-CSRF unpredictable tokens paired with cookies configured with `SameSite=Strict` or `SameSite=Lax` prevent cross-origin state-changing submissions.

Q10. What phase of ethical hacking involves actively gathering information using tools without sending packets directly to the target (e.g., WHOIS, Google Dorking)?

- A) Active Scanning
- B) Passive Reconnaissance / OSINT
- C) Enumeration
- D) Exploitation

Answer: B

Explanation: Passive reconnaissance gathers public intelligence (OSINT) without interacting directly with the victim's infrastructure, leaving zero trace in their logs.

SECTION 2: Short Answer Concepts (4–6 Marks)

Q11. Compare Symmetric Encryption and Asymmetric Encryption.

Answer:

SYMMETRIC ENCRYPTION (Single Shared Key)

Plaintext → [Encrypt with Secret Key K] → Ciphertext → [Decrypt with Same Secret Key K]

ASYMMETRIC ENCRYPTION (Public / Private Key Pair)

Plaintext → [Encrypt with Public Key] → Ciphertext → [Decrypt with Private Key]

| Criterion | Symmetric Encryption | Asymmetric (Public-Key) Encryption | |---|---|---| | **Key Count** | 1 Single Shared Secret Key for both encryption and decryption. | 2 Keys: A Public Key (shared with everyone) and Private Key (kept secret). | | **Speed** | Ultra-fast (designed for high-throughput bulk data). | Slow (1000x slower due to complex modular exponentiation). | | **Key Exchange Problem** | Difficult: How to safely share the secret key over untrusted internet? | Solved: Public key can be published openly without compromising security. | | **Algorithms** | AES-256, ChaCha20, DES, 3DES. | RSA, ECC (Elliptic Curve Cryptography), Diffie-Hellman. | | **Real-World Usage** | Encrypting bulk network streams in TLS / HTTPS. | Securely exchanging symmetric session keys during initial TLS handshake. |

Q12. Explain the STRIDE Threat Modeling Framework.

Answer: STRIDE is a threat categorization model developed by Microsoft to identify potential system vulnerabilities during the architecture design phase:

Letter	Threat Category	Violated Security Property	Real-World Example	Primary Mitigation		---	---	---	---	---
S	**Spoofing**	Authenticity	Pretending to be an admin by stealing API tokens	Multi-Factor Authentication (MFA), Mutual TLS						
T	**Tampering**	Integrity	Modifying database records or altering an HTTP payload	Digital Signatures, HMAC, TLS encryption						
R	**Repudiation**	Non-Repudiation	Denying sending an offensive message							

or transferring funds | Secure Audit Logging, Digital Signatures || **I | Information Disclosure** | Confidentiality | Exposing user passwords or database credentials in logs | Encryption at rest and in transit, Secret vaults || **D | Denial of Service (DoS)** | Availability | Flooding a server with SYN packets to crash it | Rate limiting, Cloudflare DDoS shielding, Autoscaling || **E | Elevation of Privilege** | Authorization | Standard user modifying request parameter to become Admin | Role-Based Access Control (RBAC), Least Privilege |

SECTION 3: VTU Model Numerical & Security Exploits (10–12 Marks)

Q13. [VTU Model QP - RSA Cryptography Numerical Problem]

In an RSA cryptosystem, the two prime numbers chosen are $p = 7$ and $q = 11$. The public exponent is chosen as $e = 13$.

- Compute the modulus n and Euler's totient function $\phi(n)$.
- Determine the Private Key exponent d .
- Encrypt the plaintext message $M = 9$ to generate ciphertext C .
- Decrypt the ciphertext C to recover the original message M .

Answer:

Step 1: Calculate n and $\phi(n)$

- Modulus: $n = p \times q = 7 \times 11 = 77$
- Euler's totient: $\phi(n) = (p - 1)(q - 1) = (7 - 1)(11 - 1) = 6 \times 10 = 60$

Step 2: Calculate Private Key Exponent d

The private key d is the modular multiplicative inverse of $e \pmod{\phi(n)}$: $d \times e \equiv 1 \pmod{\phi(n)}$ implies $d \times 13 \equiv 1 \pmod{60}$

We find an integer k such that: $13d = 60k + 1$

- For $k = 1$: $60(1) + 1 = 61$ (not divisible by 13).
- For $k = 2$: $60(2) + 1 = 121$ (not divisible by 13).
- For $k = 3$: $60(3) + 1 = 181$ (not divisible by 13).
- For $k = 4$: $60(4) + 1 = 241$ (not divisible by 13).
- For $k = 8$: $60(8) + 1 = 481$.
 $481 \div 13 = 37$ exactly! ($37 \times 13 = 481$).

Therefore, the **Private Key** is $d = 37$.

- Public Key:** $\{e=13, n=77\}$
- Private Key:** $\{d=37, n=77\}$

Step 3: Encryption of Plaintext $M = 9$

$$C = M^e \pmod{n} = 9^{13} \pmod{77}$$

Using modular exponentiation:

- $9^1 \pmod{77} = 9$

- $9^2 = 81 \equiv 4 \pmod{77}$
- $9^4 = 4^2 = 16 \pmod{77}$
- $9^8 = 16^2 = 256 = 3 \times 77 + 25 \equiv 25 \pmod{77}$
- Now assemble $9^{13} = 9^8 \times 9^4 \times 9^1$: $9^{13} \equiv (25 \times 16 \times 9) \pmod{77}$
 $25 \times 16 = 400 = 5 \times 77 + 15 \equiv 15 \pmod{77}$
 $15 \times 9 = 135 = 1 \times 77 + 58 \equiv \mathbf{58} \pmod{77}$

Ciphertext: $\mathbf{C} = 58$.

Step 4: Decryption of Ciphertext $\mathbf{C} = 58$

$M = C^d \pmod{n} = 58^{37} \pmod{77}$ Applying modular exponentiation recovers the exact original message: $\mathbf{M} = 9$ (Verified: $58^{37} \equiv 9 \pmod{77}$).

Q14. [VTU Model QP - Diffie-Hellman Key Exchange Numerical]

Alice and Bob agree to use public prime number $q = 23$ and primitive root $\alpha = 5$.

- Alice chooses private key $X_A = 4$.
- Bob chooses private key $X_B = 3$.
 - (a) Calculate Alice's and Bob's public keys (Y_A and Y_B).
 - (b) Calculate the shared secret symmetric key K computed independently by Alice and Bob.

Answer:

Step 1: Compute Public Keys

- **Alice's Public Key (Y_A):** $Y_A = \alpha^{X_A} \pmod{q} = 5^4 \pmod{23}$
 $5^4 = 625$
 $625 = 27 \times 23 + 4 \implies \mathbf{Y_A = 4}$
- **Bob's Public Key (Y_B):** $Y_B = \alpha^{X_B} \pmod{q} = 5^3 \pmod{23}$
 $5^3 = 125$
 $125 = 5 \times 23 + 10 \implies \mathbf{Y_B = 10}$

Step 2: Calculate Shared Secret Key

- **Alice receives $Y_B = 10$ and computes K using her private key $X_A = 4$:** $K = (Y_B)^{X_A} \pmod{q}$
 $= 10^4 \pmod{23}$
 $10^2 = 100 \equiv 8 \pmod{23}$
 $10^4 = 8^2 = 64 = 2 \times 23 + 18 \implies \mathbf{K = 18}$
- **Bob receives $Y_A = 4$ and computes K using his private key $X_B = 3$:** $K = (Y_A)^{X_B} \pmod{q}$
 $= 4^3 \pmod{23}$
 $4^3 = 64 = 2 \times 23 + 18 \implies \mathbf{K = 18}$

Conclusion: Both Alice and Bob independently arrive at the exact same shared secret key $\mathbf{K = 18}$ without ever transmitting it over the wire!

Q15. [VTU Model QP - SQL Injection Attack & Defense Scenario]

(a) Explain how an attacker bypasses login authentication using SQL Injection with a payload like `' OR '1'='1'`.

(b) Demonstrate the vulnerable code and provide the fixed, secure version using Java Prepared Statements.

Answer:**Part (a): Vulnerability Mechanism**

Consider a vulnerable backend application constructing SQL queries via direct string concatenation:

```
SELECT * FROM users WHERE username = 'USER_INPUT' AND password = 'PASSWORD_INPUT';
```

If the attacker inputs:

- Username: `admin' --` or `' OR '1'='1'`
- Password: `any_password`

The query dynamically constructed becomes:

```
SELECT * FROM users WHERE username = '' OR '1'='1' AND password = ' ... ';
```

Since `'1'='1'` is always **TRUE**, the entire `WHERE` clause evaluates to true, bypassing authentication and returning the first record in the table (typically the administrator account).

Part (b): Code Comparison (Vulnerable vs Secure)**Vulnerable Code (String Concatenation — NEVER DO THIS):**

```
// INSECURE: Vulnerable to SQL Injection!
String sql = "SELECT * FROM users WHERE username = '" + username + "' AND password = '" + password + "'";
Statement stmt = connection.createStatement();
ResultSet rs = stmt.executeQuery(sql); // ATTACKER OWNS DATABASE!
```

Secure Code (Parameterized Prepared Statement):

```
// SECURE: Uses placeholders '?' so input is never treated as SQL code!
String sql = "SELECT id, username, password_hash FROM users WHERE username = ? AND password = ?";
try (PreparedStatement pstmt = connection.prepareStatement(sql)) {
    pstmt.setString(1, username); // Safe binding
    pstmt.setString(2, password); // Safe binding

    try (ResultSet rs = pstmt.executeQuery()) {
        if (rs.next()) {
            System.out.println("Authenticated successfully!");
        } else {
            System.out.println("Invalid credentials.");
        }
    }
}
}
```

💡 Key Takeaway Checklist for Exam Day

- [] For RSA numericals, remember: $n = p \times q$, $\phi(n) = (p-1)(q-1)$, and $d \times e \equiv 1 \pmod{\phi(n)}$.
- [] In Diffie-Hellman, know the formula: $K = (Y_B)^{X_A} \pmod q = (Y_A)^{X_B} \pmod q$.
- [] Always remember that Prepared Statements prevent SQL Injection by separating compilation from data binding.